GRC206 SECURITY AWARENESS PROGRAMME

Northbridge Logistics: Enterprise Security Behaviour & Culture Design

A Practical Operational Framework Grounded in the Five-Stage Security Awareness Lifecycle (Assess → Plan → Deliver → Measure → Improve)

Course: GRC206 - Information Governance, Risk and Compliance
Target Organisation: Northbridge Logistics Ltd.
Student Name: SAMUEL ADEOLUWA OKUNRIBIDO
Student ID: GCR2512878
Official Email: gcr2512878@students.icdfa.edu.ng
Submission Date: November 2026
Academic Year: 2025 / 2026

GRC206 SECURITY AWARENESS PROGRAMME 1
2. Executive Summary 2
3. Lab Objectives 2
4. Tools and Resources Used 3
5. Organisational Assumptions 3
Task 1 – Assess (Risks, Audiences, Baseline) 5
6.1 Top Three Human-Driven Risks 5
Risk 1: Business Email Compromise (BEC) and Invoice Redirection Fraud 5
Risk 2: Password Reuse and Weak Credential Hygiene 5
6.2 Audience Segmentation 5
6.3 Pre-Launch Baseline Assessment 6
7.1 Three Measurable Objectives (12-Month Horizon) 6
7.2 Programme Governance Framework 7
7.3 Curriculum Topics Mapped Directly to Risks 7
8. Task 3 – Deliver (Formats, Onboarding, Simulations, Reporting) 8
8.1 Delivery Formats Tailored to Working Realities 8
8.2 New Starter Onboarding Pathway 9
8.3 Phishing Simulation Strategy: Constructive, Progressive, and Non-Punitive 9
8.4 Frictionless, No-Blame Reporting Infrastructure 9
9. Task 4 – Measure (Four Metrics + Leadership Reporting) 9
9.1 Four Core Performance Metrics 9
9.2 Executive Reporting: The One-Page Quarterly Dashboard 10
10. Task 5 – Improve and Sustain 10
10.1 Structured Quarterly Review & Feedback Architecture 10
10.2 Embedding Security Champions & Positive Recognition 11
11. 12-Month Programme Calendar 11
12. Analysis and Findings 12
13. Main Challenges 13
14. Conclusions and Recommendations 13
15. Short Reflection 14
16. References 14
17. Acknowledgement 14

2. Executive Summary

Northbridge Logistics is a mid-sized national third-party logistics (3PL) provider employing approximately 800 staff across corporate headquarters, regional fulfillment warehouses, and a distributed mobile sales force. The organization faces a critical inflection point in its cyber risk posture. A series of recent security incidents which may be including sophisticated supplier impersonation/Business Email Compromise (BEC) attempts and multiple occurrences of post-breach corporate credential reuse and have highlighted severe vulnerabilities in human security behaviour. These operational risks are compounded by the company's custody of sensitive, regulated customer commercial data and personal information, creating substantial regulatory and legal liability under applicable data protection frameworks.

This document articulates a practical, high-impact 12-month Security Awareness Programme engineered specifically around the operational realities of Northbridge Logistics: a lean three-person cybersecurity team, modest financial resources (capped at £12,000–£15,000), a highly heterogeneous workforce with starkly varying computer access, and 24/7 logistics shift schedules. Designed strictly according to the five-stage security awareness lifecycle—Assess, Plan, Deliver, Measure, and Improve the programme deliberately rejects unfocused annual 'check-the-box' compliance training. Instead, it deploys a calibrated, audience-segmented intervention model targeting three decisive behavioral vectors: financial fraud verification, rigorous credential and multi-factor authentication (MFA) hygiene, and the cultivation of an active, psychological safety-driven reporting culture.

> **STRATEGIC CHARTER & TARGETS:** Target Outcomes at Month 12: ≥ 50% reduction in successful invoice-fraud/BEC incidents; ≥ 85% role-specific module completion across all audiences; ≥ 90% enterprise MFA adoption; phishing simulation click rates suppressed to ≤ 8% with active reporting elevated to ≥ 40%.

3. Lab Objectives

The primary objective of this project is to operationalize cybersecurity governance principles into an actionable, sustainable awareness and culture transformation programme within a constrained operating environment. Specifically, the objectives comprise:

- **Lifecycle Alignment:** Design an end-to-end security behaviour change programme directly mapped to the five-stage lifecycle model (Assess, Plan, Deliver, Measure, Improve) in compliance with NIST SP 800-50 and ISO/IEC 27001:2022 Control 7.2.
- **Human Risk Mitigation:** Directly remediate Northbridge Logistics' empirical risk exposures—specifically Business Email Compromise, invoice redirection fraud, compromised credential reuse, and acute reporting friction.
- **Audience-Specific Instructional Design:** Construct tailored pedagogical delivery models adapted to four distinct organisational cohorts, specifically solving the logistical challenge of engaging non-desk warehouse shift workers.
- **Quantitative Governance & Metrics:** Establish an objective, data-driven measurement framework spanning Reach, Behaviour, and Real-World Outcomes, supported by an executive reporting cadence.
- **Operational Sustainability:** Demonstrate that meaningful culture change can be achieved without enterprise-scale budgets or dedicated training headcount through pragmatic governance, automation, and continuous feedback loops.

4. Tools and Resources Used

The programme utilizes existing, vendor-neutral core capabilities that an established mid-sized enterprise possesses all are assumed with possible realistic method:

Resource / Capability	Operational Function	Architecture / Deployment Mode
Existing Central LMS	Module hosting, user assignment, SCORM tracking, completion and quiz score reporting.	Internal Learning Management System; web and mobile kiosk compatible.
Central Identity & Access Directory	Directory services, single sign-on (SSO), MFA enforcement, and authentication event auditing.	Directory audit logs exported via scheduled script to identify MFA gaps and breach hash collisions.
Open/Modular Phishing Framework	Simulated social engineering campaign execution, automated payload tracking, immediate landing page delivery.	Open-source or lightweight modular phishing simulation software operated directly by internal IT staff.
Internal Helpdesk Ticketing System	Incident intake, triage categorization, resolution SLA tracking, and audit trail maintenance.	Designated security queue with custom tagging for employee suspicious message submissions.
Collaborative Digital Channels	Asynchronous company-wide announcements, digital bulletin boards, and shift-briefing distribution.	Standard corporate intranet and team messaging channels accessible on shared devices.
Physical Operational Media	Analogue visual reinforcement in industrial environments.	Laminated high-visibility job aids, loading bay visual posters, and shift handover briefing sheets.

5. Organisational Assumptions

The programme architecture is strictly bounded by baseline assumptions regarding Northbridge Logistics' operational environment, human capital, technology stack, and fiscal parameters:

a. **Security Staffing Ceiling:** The internal Information Security team consists strictly of three individuals: one Security Manager (overseeing strategy, governance, and policy), one Security Specialist (managing operations, simulations, and triage), and an IT Support generalist allocating 25% FTE to technical directory and log administration. No dedicated security awareness or communications personnel exist.

b. **Learning & Development Partnership:** The enterprise Human Resources/L&D function contributes one shared Learning Partner allocating approximately 10% FTE (4 hours/week) to assist with LMS user management, automated onboarding enrollments, and shift training coordination.

c. **Fiscal Constraints:** The maximum allocated annual budget for awareness, external content licensing, printing, and campaign collateral is strictly capped at £12,000–£15,000, prohibiting expensive bespoke external consultancies.

d. **Workforce Distribution & Operational Schedule:** Northbridge Logistics employs 800 staff distributed across: (a) Warehouse & Logistics Operatives (~450 staff working 24/7 rotating shifts across 4 regional hubs with negligible personal computer access); (b) Head Office, Finance, & Administration (~150 staff based at corporate headquarters with dedicated desktop environments); (c) Remote Sales & Field Operations (~150 staff operating across dynamic geographic territories using laptops and smartphones); and (d) Line Managers & Supervisors (~50 staff distributed across all sites).
e. **Technical & Logging Capabilities:** Corporate identity directories capture user authentication timestamps and MFA enablement status, but lack automated behavioural AI risk telemetry. The ticketing system supports basic email ingestion and custom categorization, but lacks automated malware sandbox detonation.

Task 1 – Assess (Risks, Audiences, Baseline)

6.1 Top Three Human-Driven Risks

A rigorous risk assessment must reflect the threat vectors actively converging on Northbridge Logistics' operational model rather than generic threat catalogues. The three primary human-driven risks are:

Risk 1: Business Email Compromise (BEC) and Invoice Redirection Fraud

Threat Dynamics: Attackers actively target Northbridge's commercial supply chain, executing sophisticated social engineering schemes that impersonate known logistics suppliers, subcontractors, or senior executives requesting urgent bank account modifications or expedited supplier disbursements.
Organisational Vulnerability: Accounts Payable and procurement workflows operate under aggressive fulfillment SLAs. Remote sales and operational staff frequently transmit informal billing requests via email while off-site.
Potential Impact: Catastrophic direct financial capital loss through unauthorized wire transfers, secondary breach of regulated customer commercial shipping data, severe reputational destruction, and regulatory reporting triggers.

Risk 2: Password Reuse and Weak Credential Hygiene

Threat Dynamics: Exploitation of widespread employee credential reuse across consumer and professional accounts. Following public third-party database breaches, threat actors deploy automated credential-stuffing attacks against Northbridge's perimeter access portals.
Organisational Vulnerability: Two documented incidents of post-breach password reuse occurred recently. Warehouse staff frequently utilize shared administrative terminals without individual logout, while legacy systems feature incomplete MFA coverage.
Potential Impact: Unauthorized administrative or corporate network penetration, credential escalation, deployment of ransomware across logistics operational technology, and regulatory sanctions under data privacy statutes.

Risk 3: Low Recognition and Friction-Laden Reporting of Suspicious Messages

Threat Dynamics: Delivery of opportunistic and targeted credential-harvesting, malicious payload attachments, and QR code-based phishing (quishing) concealed within legitimate logistical operational notices.
Organisational Vulnerability: Warehouse floor operatives and field sales personnel process hundreds of fast-paced shipping manifests and electronic delivery proofs daily on mobile screens. Furthermore, the absence of a visible, frictionless reporting route—coupled with employee fear of disciplinary reprisal—leads staff to either passively delete threats or overlook them entirely.
Potential Impact: Latent dwell time for undetected intrusions, loss of security operations team visibility into active phishing waves, and severely delayed incident containment.

6.2 Audience Segmentation

To maximize instructional efficacy and respect operational workflows, the 800 employees are segmented into four distinct cohorts with tailored training interventions:

Audience Segment	Headcount	Operational Reality & Access Constraints	Core Pedagogical & Security Focus
Warehouse & Logistics	~450	Operate in dynamic warehouse	Physical perimeter security,

Audience Segment	Headcount	Operational Reality & Access Constraints	Core Pedagogical & Security Focus
Operatives		environments; 24/7 rotating shifts; no dedicated PCs; access via shared floor kiosks, wall-mounted tablets, or personal smartphones.	loading bay social engineering, tailgate prevention, terminal auto-lock, QR phishing, quick reporting.
Head Office: Finance, HR & Procurement	~150	Dedicated desk terminals; high daily volume of financial, contractual, and sensitive personal employee/customer data.	Mandatory out-of-band verification for payment changes, dual-authorization enforcement, payroll fraud, spear-phishing triage.
Remote Sales & Field Operations	~150	Highly mobile, domestic/field travel; access corporate systems via laptops/smartphones over public Wi-Fi; fast-paced deal closing.	Public Wi-Fi hazards, VPN discipline, visual eavesdropping, device theft/loss protocols, off-site client payment modifications.
People Managers & Team Leaders	~50	Direct supervisory authority across warehouse hubs and functional departments; gatekeepers of team operational time.	Fostering non-punitive culture, modeling security compliance, running shift briefings, incident escalation, psychological safety.

6.3 Pre-Launch Baseline Assessment

A formal 30-day pre-launch empirical baseline is executed prior to deploying educational content, capturing authentic organizational risk metrics:

a. **Diagnostic Phishing Benchmark:** Execution of a single, benign baseline phishing simulation across all corporate mailboxes without advance notification, utilizing a standard delivery notification lure to capture unconditioned baseline Click Rate and Report Rate.
b. **Identity & Access Audit:** Extraction of directory authentication telemetry to establish current enterprise-wide MFA enrollment percentages, identification of legacy single-factor exceptions, and matching employee corporate emails against verified public breach databases.
c. **Historical Incident Telemetry Review:** A 6-month retrospective audit of helpdesk security tickets and finance incident logs to quantify confirmed invoice-fraud attempts, near-misses, and employee-generated suspicious email reports.
d. **Knowledge & Perception Diagnostic Survey:** Deployment of a brief, anonymous 10-question pulse survey assessing workforce familiarity with payment verification rules, password manager usage, and perceived barriers or fears regarding incident reporting.

7. Task 2 – Plan (Objectives, Governance, Topics)

7.1 Three Measurable Objectives (12-Month Horizon)

All performance targets represent deliberate planning commitments calibrated to provide realistic stretch goals for Northbridge Logistics over a 12-month timeline:

Objective 1: Invoice Fraud & BEC Incident Suppression (Outcome Metric)

Achieve a minimum 50% reduction in confirmed successful invoice fraud and unauthorized payment redirection incidents by Month 12 relative to the pre-launch baseline, while achieving 100% compliance with out-of-band callback verification across the Accounts Payable team.

Objective 2: Enterprise Curriculum Reach & Credential Hygiene (Reach & Hygiene Metric)

Attain ≥ 85% completion of mandatory role-specific security modules across all four workforce cohorts within six months of launch, and achieve ≥ 90% verified MFA adoption across all active user directory accounts by Month 9.

Objective 3: Resilience Elevation & Threat Reporting (Behavioural Metric)

Increase employee suspicious message reporting rates to ≥ 40% across quarterly simulated campaigns by Month 12, while concurrently compressing simulated phishing click susceptibility rates to ≤ 8% enterprise-wide.

7.2 Programme Governance Framework

A lean, robust governance structure distributes operational responsibility across key organizational stakeholders without imposing excessive administrative burden:

a. **Executive Sponsor (Chief Operating Officer):** Maintains ultimate accountability for enterprise risk; approves programmatic resource allocation; signs off on mandatory compliance policies; unblocks operational logjams across regional warehouse facilities.
b. **Programme Owner (Security Manager):** Responsible for end-to-end curriculum architecture, lifecycle execution, metric analysis, executive dashboard authoring, and chairing quarterly steering reviews.
c. **Technical Lead (Security Specialist):** Directly operates simulation platforms, configures reporting plug-ins, engineers curriculum delivery formats, and performs Tier-2 triage on employee threat reports.
d. **Operational Enabler (L&D Partner - 10% FTE):** Oversees LMS catalog configuration, manages user enrollment synchronization, monitors shift-level compliance exceptions, and embeds modules into new-hire onboarding.
e. **Departmental Advocates (Shift Supervisors & Team Leads):** Act as on-the-ground champions; facilitate shift-briefing discussions; reinforce non-punitive messaging; ensure kiosk terminal access during scheduled handover windows.

7.3 Curriculum Topics Mapped Directly to Risks

Every instructional topic maps directly back to the empirical risks identified in Task 1, preventing extraneous content saturation:

Risk Vector Addressed	Target Audience	Instructional Content & Behavioral Imperative
BEC & Invoice Redirection	Head Office (Finance/Procurement) & Remote Sales	Mandatory out-of-band verification via known phone contacts for any bank detail amendment; dual-authorization controls; identifying spoofed vendor domains.
Credential Reuse & Weak Hygiene	All Workforce Segments (Universal)	Passphrase generation techniques; unique credential discipline; dangers of personal-professional password overlap; step-by-step MFA setup and

Risk Vector Addressed	Target Audience	Instructional Content & Behavioral Imperative
		token security.
Under-Reporting & Phishing	All Workforce Segments (Universal)	Recognizing social engineering triggers (urgency, authority, fear); identifying quishing / malicious QR codes; using the one-click reporting mechanism.
Physical Security & Terminal Access	Warehouse & Logistics Operatives	Preventing loading bay tailgating; physical security around logistics dispatch computers; workstation locking (Win+L / terminal logout); reporting unidentified visitors.
Mobile & Remote Threat Vectors	Remote Sales & Field Operations	Securing public Wi-Fi via VPN; visual eavesdropping / privacy screens in public transit; lost/stolen device immediate containment protocols.

8. Task 3 – Deliver (Formats, Onboarding, Simulations, Reporting)

8.1 Delivery Formats Tailored to Working Realities

Recognizing that standard e-learning fails in industrial and field contexts, delivery channels are strictly tailored to daily operational cadences:

Warehouse Operatives: Micro-Learning & Operational Touchpoints

Content is compressed into ultra-short 3-to-5 minute interactive modules deployed via mobile-responsive LMS links, allowing completion on personal smartphones or warehouse floor touchscreen kiosks during pre-shift briefings. This is reinforced through physical, laminated job aids mounted at dispatch stations and supervisor-led 2-minute 'Toolbox Talks' delivered bi-weekly at shift handovers.

Head Office & Finance: Scenario Workshops & Interactive Modules

Personnel complete 15-to-20 minute desktop e-learning modules featuring interactive branching scenarios. In addition, the Finance and Procurement teams participate in bi-annual, 45-minute live tabletop exercises simulating an active, high-urgency supplier payment alteration request to pressure-test dual-control verification procedures.

Remote Sales & Field Staff: Mobile-First Audio/Visual Digests

Delivery utilizes podcast-style 5-minute audio briefings, mobile-optimized quick scenarios, and push notifications via corporate collaboration tools designed to be consumed during transit downtime without requiring desk access.

People Managers: Coaching Toolkits & Discussion Guides

Supervisors receive concise, single-page briefing cards outlining key talking points, instructions on recognizing safe security behaviours, and clear protocols for handling employee-reported security mistakes supportively.

8.2 New Starter Onboarding Pathway

Security awareness is embedded into employee onboarding to eliminate operational latency. Within the first five working days, all new hires must complete a mandatory 20-minute core security orientation covering credential management, phishing recognition, and incident reporting. HR workflows enforce automated module assignment upon directory account provisioning. For warehouse personnel, the shift supervisor conducts an in-person physical walkthrough on Day 1, demonstrating terminal locking, badge access, and reporting kiosk operation.

8.3 Phishing Simulation Strategy: Constructive, Progressive, and Non-Punitive

Simulations are conducted quarterly as pedagogical reinforcement rather than punitive compliance traps. The campaign evolves progressively: Q1 features obvious credential-harvest lures; Q2 introduces delivery and dispatch tracking lures; Q3 simulates internal operational notices; and Q4 introduces sophisticated invoice modification scenarios targeting finance. Crucially:

a. **Immediate Teachable Moments:** Interacting with a simulated link redirects the user to a respectful, non-judgmental guidance page detailing the specific red flags present in the message, reinforcing immediate self-correction.
b. **Psychological Safety & Data Privacy:** Individual simulation performance data is strictly confidential to the cybersecurity team. Line managers receive only aggregated, anonymized department-level susceptibility metrics. Phishing failure is never incorporated into formal disciplinary proceedings or performance appraisals.
c. **Repeat Vulnerability Coaching:** Employees who fail two consecutive simulations are assigned a supportive, 1-on-1 coaching session with a security specialist to address operational hurdles and provide personalized guidance.

8.4 Frictionless, No-Blame Reporting Infrastructure

To achieve a 40% reporting rate, reporting friction must be systematically removed. An intuitive, single-click 'Report Suspicious' plug-in is integrated directly into the corporate email client. For warehouse operatives lacking dedicated email clients, prominent QR codes and desktop shortcuts on kiosk terminals direct users to a simplified 3-field web submission form. The intake system automatically generates an appreciative confirmation receipt within 4 business hours, providing status updates. A strict 'No-Blame Culture Policy' is codified in writing: no employee will face disciplinary action for reporting a genuine mistake, accidental click, or security anomaly, establishing reporting as an act of enterprise stewardship.

9. Task 4 – Measure (Four Metrics + Leadership Reporting)

9.1 Four Core Performance Metrics

Evaluation moves beyond passive vanity metrics by implementing a balanced measurement scorecard spanning curriculum reach, actual behaviour change, credential posture, and business risk outcomes:

Metric Name & Type	Operational Definition & Calculation	Data Source & Owner	Review & Target Cadence
1. Curriculum Reach (Reach Metric)	Completion Rate (%) = (Total Staff Completed Assigned Modules / Total Target Population) × 100	LMS Database; Owner: L&D Partner	Monthly tracking; Target: ≥ 85% by Month 6 across all 4 cohorts.

Metric Name & Type	Operational Definition & Calculation	Data Source & Owner	Review & Target Cadence
2. Threat Reporting Rate (Behavioural Metric)	Reporting Rate (%) = (Suspicious Message Reports / Total Phishing Invocations) × 100	Phishing Tool & Helpdesk; Owner: Security Specialist	Quarterly review; Target: ≥ 40% reporting across campaigns by Month 12.
3. MFA Adoption Rate (Hygiene Metric)	MFA Rate (%) = (Active Directory Accounts with Enforced MFA / Total Active Accounts) × 100	Directory Audit Logs; Owner: Security Manager	Monthly review; Target: ≥ 90% enforced enterprise-wide by Month 9.
4. Invoice Fraud Loss (Outcome Metric)	Count of verified unauthorized payment modifications, successful fraud attempts, and near-misses.	Finance ERP & Security Log; Owner: Security Manager & Finance	Quarterly review; Target: ≥ 50% incident reduction by Month 12.

9.2 Executive Reporting: The One-Page Quarterly Dashboard

Senior leadership requires concise risk intelligence rather than operational trivia. The Security Manager compiles a standardized one-page Executive Dashboard delivered to the Chief Operating Officer and executive committee at the conclusion of each quarter. The dashboard features:

a. **Strategic OKR Trajectory:** A high-level RAG (Red/Amber/Green) status indicator tracking progress against the three core 12-month objectives.
b. **Lifecycle Metric Scorecard:** A comparative table contrasting current Reach, Behaviour, Hygiene, and Outcome metrics against pre-launch baseline figures and quarterly milestones.
c. **Cohort Risk Heatmap:** A visual matrix identifying specific operational sectors (e.g., Regional Hub 2 warehouse vs. Central Logistics) experiencing training deficits or elevated susceptibility.
d. **Actionable Executive Requests:** A concise narrative outlining systemic roadblocks requiring executive intervention (e.g., funding for hardware tokens in warehouse zones, or managerial enforcement of out-of-band invoice verification).

10. Task 5 – Improve and Sustain

10.1 Structured Quarterly Review & Feedback Architecture

To ensure the programme does not stagnate, formal quarterly reviews occur at Months 3, 6, 9, and 12. Led by the Security Manager, this review convenes the Security Specialist, L&D Partner, Head of Finance, and a rotating Warehouse Operations Manager. The review evaluates telemetry from the four core metrics, analyzes near-miss incident logs, and systematically incorporates qualitative feedback captured via anonymous 3-question pulse surveys embedded at the end of every module. Discovered content deficiencies, shifting threat landscapes (e.g., emergent vendor invoice fraud formats), or operational friction points are documented in a formal remediation tracker with designated operational owners and 30-day resolution windows.

10.2 Embedding Security Champions & Positive Recognition

Cultural sustainability requires continuous peer reinforcement. Northbridge establishes a voluntary 'Security Champions Network' comprising 8–10 enthusiastic operational staff across warehouse facilities and corporate departments. Champions receive specialized 30-minute monthly briefings, providing front-line peer coaching and early warning intelligence on emerging operational practices. Furthermore, positive reinforcement is formalized through a monthly 'Security Spotter Award'—recognizing employees who rapidly report genuine suspicious communications or identify operational security flaws. Winners receive peer recognition in company newsletters and a modest voucher (£25), reframing cybersecurity from an oppressive barrier into an esteemed professional virtue.

11. 12-Month Programme Calendar

The 12-month calendar organizes all activities across the five lifecycle stages, establishing an achievable operational workload for the three-person security team:

Month	Lifecycle Phase	Operational Delivery & Focus	Target Audience	Governance / Metric Milestone
M01	Assess	Conduct baseline phishing simulation; audit directory MFA; deploy pulse diagnostic survey.	All Staff (800)	Baseline empirical report compiled; COO sign-off.
M02	Plan / Deliver	Formal programme launch; roll out Module 1 (Credentials & MFA); publish Manager Toolkits.	All Staff & Managers	Automated onboarding pipeline live; monthly completion review.
M03	Deliver / Measure	Execute Phishing Campaign 1 (Basic Credential Lure); launch Warehouse micro-modules.	Finance, Remote, Warehouse	Q1 Executive Review; Metric review: Baseline vs Q1.
M04	Deliver	Roll out Module 2 (BEC & Invoice Fraud); conduct live Finance out-of-band workshop.	Finance, Procurement, Sales	Pulse feedback review; AP callback compliance check.
M05	Deliver / Measure	Warehouse supervisor Toolbox Talks refresh; targeted enterprise MFA enablement push.	Warehouse Operatives, All	Directory audit: evaluate progress toward 90% MFA.
M06	Deliver / Measure	Execute Phishing Campaign 2 (Logistics Dispatch Lures); mid-year curriculum review.	All Staff (800)	Q2 Executive Dashboard; Milestone: ≥ 85% core completion.
M07	Improve	Curriculum remediation based on Q2 feedback;	Managers & Champions	Refined content deployment;

Month	Lifecycle Phase	Operational Delivery & Focus	Target Audience	Governance / Metric Milestone
		launch Security Champions Network.		Champions kick-off.
M08	Deliver / Measure	Execute Phishing Campaign 3 (Sophisticated Internal Notification); Mobile Safety push.	Remote Sales & Office	Evaluate simulation report rate vs 40% target.
M09	Deliver / Measure	Targeted 1-on-1 coaching for repeat clickers; launch 'Security Spotter' recognition.	All Staff (800)	Q3 Executive Dashboard; Milestone: ≥ 90% enterprise MFA.
M10	Deliver	Deploy Module 3 (Physical Security, Tailgating & Loading Bay Hygiene); visual job-aids.	Warehouse & Facilities	Warehouse kiosk access review; pulse diagnostic.
M11	Deliver / Measure	Execute Phishing Campaign 4 (Advanced Invoice Redirection Scenario); annual audit prep.	Finance & Remote Staff	Simulation susceptibility analysis; fraud logs review.
M12	Measure / Improve	Execute annual security culture survey; compile annual programme performance report.	All Staff & Leadership	Q4 Final Executive Report; presentation of Year 2 Strategy.

12. Analysis and Findings

Analysis of Northbridge Logistics' operational context reveals that traditional cybersecurity awareness programmes fail primarily due to socio-technical dissonance rather than user apathy. Key findings include:

a. **The Non-Desk Disconnect:** Over 56% of the workforce (~450 warehouse operatives) do not sit at a computer. Mandating traditional 45-minute annual desktop e-learning alienates shift staff, degrades operational productivity, and results in superficial compliance. Security education must be seamlessly integrated into existing shift rhythms and mobile surfaces.

b. **The Efficiency-Security Tradeoff in Finance:** Recent invoice fraud attempts succeeded because financial workflows prioritized speed over rigorous out-of-band authentication. Training alone cannot fix this without strict operational policy enforcement—specifically requiring dual-authorization callbacks on all bank changes over £1,000.

c. **Under-Reporting Stems from Cultural Friction:** Low reporting rates are driven by complex reporting workflows and the psychological fear of disciplinary reprisal. Transitioning to a single-click mechanism supported by a transparent, codified 'No-Blame Policy' is essential to transforming passive victims into an active sensory defense network.

13. Main Challenges

The execution of this programme faces four distinct operational and environmental hurdles, accompanied by proactive mitigation strategies:

Identified Operational Challenge	Root Cause & Risk Exposure	Engineered Mitigation Strategy
1. Warehouse Shift Constraints & Time Scarcity	Tight logistics turnarounds make supervisors reluctant to release staff for computer-based training.	Deliver bite-sized 3-minute micro-learning modules integrated directly into scheduled shift-changeover briefings and toolbox talks.
2. Lean Cybersecurity Staff Capacity	A 3-person IT security team cannot sustain intensive, bespoke live training without operational burnout.	Leverage automated LMS enrollment pipelines, pre-built standardized simulation scenarios, and partner with operational managers.
3. Punitive Culture & Reporting Hesitancy	Employees fear that reporting a phishing click will lead to formal reprimand, career damage, or job termination.	Codify a strict, executive-backed No-Blame Charter; anonymize departmental metrics; celebrate fast threat reporting publicly.
4. Mobile & Remote Authentication Gaps	Field personnel operating in low-connectivity environments resist complex MFA or bypass verification checks.	Implement streamlined authentication apps, distribute hardware tokens where mobile reception fails, and enforce out-of-band phone calls.

14. Conclusions and Recommendations

Northbridge Logistics can establish a highly resilient human defense perimeter despite severe budgetary and staffing constraints. Strategic recommendations for executive leadership include:

a. **Institutionalize the No-Blame Reporting Framework:** Formally publish and endorse the corporate No-Blame Security Reporting Charter, signed jointly by the Chief Operating Officer and Human Resources Director, to dismantle reporting fear across all regional logistics hubs.
b. **Enforce Out-of-Band Payment Verification by Policy:** Codify a strict, zero-exception financial control policy requiring dual-custody phone verification via verified numbers on file for any vendor payment alteration, removing individual employee discretion.
c. **Invest in Non-Desk Digital Access:** Equip warehouse dispatch and loading bay areas with dedicated, secure micro-learning tablets or kiosks to facilitate continuous, frictionless participation for shift operatives.
d. **Sustain Pragmatic, Cadenced Governance:** Maintain the quarterly executive dashboard review cadence, ensuring that cybersecurity posture remains an ongoing leadership risk priority rather than a reactive annual audit concern.

15. Short Reflection

Designing this security awareness programme highlighted the critical balance between theoretical security ideals and operational constraints. In commercial logistics, cybersecurity is often viewed as an operational bottleneck. A security programme that ignores 24/7 warehouse turnarounds or field sales realities will fail, regardless of instructional quality. The primary insight gained was the necessity of tailoring delivery mechanisms to the operational realities of non-desk cohorts. Furthermore, shifting organizational culture from punitive compliance to psychological safety emerged as the single most critical factor in achieving high-fidelity threat reporting. Ultimately, effective cyber governance is not defined by complex software deployments, but by aligning security behaviours with daily operational workflows.

16. References

a. Bada, M., Sasse, M. A. and Nurse, J. R. C. (2019) 'Cyber security awareness campaigns: Why do they fail to change behaviour?', International Conference on Cyber Situational Awareness, Data Analytics and Assessment (CyberSA), pp. 1-8.

b. ENISA (2023) Raising Cybersecurity Awareness: A Practical Guide for Enterprises and Public Administrations. European Union Agency for Cybersecurity. Heraklion: ENISA.

c. ISO/IEC (2022) Information security, cybersecurity and privacy protection — Information security management systems — Requirements (ISO/IEC 27001:2022). Geneva: International Organization for Standardization.

d. NIST (2003) Building an Information Technology Security Awareness and Training Program (NIST Special Publication 800-50). Gaithersburg: National Institute of Standards and Technology.

e. NIST (2024) The NIST Cybersecurity Framework (CSF) 2.0. Gaithersburg: National Institute of Standards and Technology. doi: 10.6028/NIST.CSWP.29.

f. Sasse, M. A., Ashenden, D. and Lawrence, D. (2021) 'The human aspects of information security', Computer Fraud & Security, 2021(1), pp. 14-19.

g. Tsohou, A., Karyda, M. and Kokolakis, S. (2015) 'Analyzing the role of cognitive and cultural factors in information security awareness', Computers & Security, 50, pp. 69-86.

h. UK NCSC (2023) You Shape Security: Co-designing security processes with your staff. London: National Cyber Security Centre.

17. Acknowledgement

The conceptualization and structural formulation of this Security Awareness Programme were conducted in rigorous alignment with the academic brief and learning outcomes of GRC206 (Information Governance, Risk and Compliance). Appreciation is extended to the faculty and industry advisory resources for providing realistic organizational scenario parameters, and to standard cybersecurity benchmarking bodies—including the National Institute of Standards and Technology (NIST) and the National Cyber Security Centre (NCSC)—for foundational pedagogical and behavioural design frameworks. Generative AI tools were utilized under academic integrity standards solely for syntactic refinement, editorial consistency, and professional document formatting. All strategic analyses, risk mappings, operational calculations, and programme architectures represent original student academic work.